Aqua Quenchers Business Management System

Algorithm Evaluation, Information Assurance and Compliance Documentation

Document identifier: AQ-REPORT-01

Edition: 1.0 — Academic Documentation Edition

Issue date: 7 November 2026

Academic areas: Algorithms and Complexity; Information Assurance and Security

Repository: https://github.com/deo-ganub/Aqua-Quenchers-BMS

Documentation branch: algo-ias

Document Control

Item	Record
Purpose	Consolidated technical and governance documentation for academic review
Application revision assessed	owner-module bf2b43ea2ce0731ff145f5aad421979f9d3b6a7a
Separate reference implementation	424c70112d22e37dccdef41e5471e283587c0726
Extended local source assessment	de7a03b, comprising the reference baseline and unpublished login-layout change
Policy approval status	Draft privacy policy and terms; organizational adoption pending
Empirical algorithm evaluation	Reviewed-data and physical-device results pending
Security audit status	Interim source assessment; independent audit stages incomplete
Production deployment	Deferred

Abstract

The Aqua Quenchers Business Management System supports customer records, orders, inventory, payments, expenses and financial reporting for a water-refilling station. This report consolidates the proposed expense-classification methodology, reproducible benchmark protocol, draft privacy and authorized-use policies, and security-control traceability. The algorithm component uses TF-IDF features with multiclass logistic regression and a weighted Multinomial Naive Bayes comparison. The information-assurance component addresses identity, least privilege, transaction integrity, session handling, data protection and operational recovery. Evidence is classified by source revision and verification method. The application branch, separate reference implementation and historical synthetic test evidence are distinguished throughout. Reviewed-data evaluation, declared-device benchmarks, classifier integration, independent security-review completion and organizational adoption remain outstanding. The report provides a formal documentation baseline for academic assessment and subsequent implementation verification without treating planned controls or synthetic examples as completed operational results.

Contents

1. Introduction and System Context

2. Algorithm Specification and Benchmark Analysis

3. Draft Privacy Policy

4. Draft Terms and Conditions

5. Security-Control Assessment

6. Security Assessment Methodology and Status

7. Application Branch Assessment

8. OWASP Agentic Skills Assessment

9. Acceptance Criteria and Outstanding Evidence

10. References

1. Introduction and System Context

1.1 Project Scope

The system is designed for individually authorized Owner and Staff accounts at a single water-refilling station. Approved operations encompass customer and order records, pickup and delivery progress, gallons and stock reservations, cash sales, payments, expenses and financial summaries. The approved architecture uses native Java/XML Android components and Supabase services. Offline Python training and Java inference form the reference classification implementation. The classifier is advisory; an authorized Owner retains category selection and save authority.

1.2 Financial and Inventory Requirements

Quantities are whole gallons and monetary calculations use integer centavos. Approved rates are PHP 35 per gallon for Household/Walk-in and PHP 30 for Dealer orders, with counter Walk-in POS at PHP 35. Revenue by business date, cash received by actual receipt date, expenses by expense date and balances as of a reporting cutoff represent distinct measures. Net income is payments received less expenses. Backend authorization, validated transitions, payment bounds, reservations and request-identity controls are required to preserve financial and inventory integrity.

1.3 Evidence Boundaries

This edition documents the owner-module application base and a separate reference implementation. A reference code link or retained test record establishes only its stated source and conditions. It does not establish integration or equivalent verification on the application branch. Proposed controls, archived exercises and synthetic examples are not substituted for live configuration, organizational approval or empirical results. The privacy policy and terms are completed draft documents for review; neither has an effective adoption date.

2. Algorithm Specification and Benchmark Analysis

Document identifier: AQ-ALG-01

Edition: 1.0

Issue date: 7 November 2026

2.1 Research Objective and Evidence Scope

The algorithm component investigates advisory classification of station expense remarks using TF-IDF features and multiclass logistic regression, with weighted Multinomial Naive Bayes as a comparison model. The evaluation protocol follows the current Algorithms and Complexity milestone and preserves separate measures of predictive quality, computational cost and application integration.

The offline and Java reference implementations are linked at revision 424c701. The assessed owner-module application revision does not yet integrate this classifier. Existing synthetic evidence supports numerical and implementation checks within its recorded scope; it does not establish station accuracy or physical-device performance. Reviewed station data, an approved release model and the declared Owner tablet are required for the outstanding empirical evaluation. The companion notebook contains no execution outputs.

2.2 Algorithm and Experimental Controls

Research requirement	Implementation and evidence
NFKC/lowercase Unicode text, bounded unigrams/bigrams, sparse TF-IDF	text.py, features.py; training-only vocabulary/IDF; maximum500 raw and normalized codepoints,128 tokens and3000 features
Student multiclass logistic regression with stable softmax/gradient learning	models.py, training/tuning
Weighted Multinomial Naive Bayes comparison	Same models/pipeline; same frozen splits/features and reported comparison. No requirement or claim that NB must lose
Owner-reviewed labels, seven fixed categories, leakage control	data.py, label guide/template; grouped60/20/20 targets, seed42, exact/near/receipt/template grouping. Actual class counts must be reported, not assumed equal to targets
Validation-only hyperparameters and suggestion policy	Pipeline tunes LR/lambda/NB smoothing and confidence/gap using validation only; freezes policy before one held-out evaluation. Unknown/zero-feature examples stay in quality metrics; suggestions remain advisory
Once-only held-out evaluation and provenance	Frozen digests/manifests, exclusive output files and evaluation-start reservation in pipeline. A started/failed evaluation requires review; do not delete markers to retune on test labels
Pure Java/Android integration	Strict model, inference, manual-confirmation lifecycle

2.3 Evaluation Measures and Acceptance Criteria

For both models report the frozen dataset/split/source/model hashes, pseudonymous review provenance, actual per-class train/validation/test support, confusion matrix, accuracy, macro precision/recall/F1, per-class precision/recall/F1, offered-suggestion coverage/error, model bytes and environment. Distinguish accepted examples from abstention/manual fallback. Use actual held-out support; a zero-support category cannot demonstrate its recall gate. Keep error examples private/redacted. Timing repetitions are not additional independent accuracy observations.

Training timing uses benchmark.py: one fresh-process warmup, then five fresh-process prepare/train runs. Report five durations, median/range and peak RSS with CPU/OS/runtime/library versions. It never runs held-out evaluation. The reported duration includes preparation plus training/tuning; label that scope rather than presenting it as an isolated optimizer-only duration.

Device timing uses InferenceBenchmark and ClassifierDeviceBenchmark: actual declared Owner tablet, approved model,100 warm-up then1,000 timed inferences. Report median/p95, incremental Java heap including load and separate process RSS/PSS observation. Java heap does not establish process-memory growth. Record model/device/Android/thermal/background/network conditions and Android parity evidence; do not substitute host or emulator timing for tablet results.

Frozen proposed release gate	Current evidence
Held-out macro-F1 >=0.80	**Blocked:** Owner-reviewed held-out corpus/model absent
Every category recall >=0.60	**Blocked:** actual reviewed per-category held-out support/results absent
Model package <=2 MiB	Loader/export bound implemented; actual approved release artifact **Not Run**
Owner-tablet Java p95 <=100ms	Harness implemented; declared physical tablet/model **Not Run**
Incremental memory <=32 MiB	Java heap harness implemented; actual tablet/model and separate process memory **Not Run**
Python/Java/Android model agreement	Synthetic Python/Java correctness evidence retained; real frozen model and target Android Unicode/runtime parity **Not Run**

Freeze these gates before final testing. Report failures honestly; do not lower thresholds after seeing held-out results. Historical prototype values, synthetic timing and a code-complete harness cannot fill these result cells.

2.4 Reproducibility Procedure

Use an approved isolated offline environment with dependencies already installed from pinned requirements. Start in this repository root, use private absolute dataset/output paths, a clean reviewed source commit and a **new** output directory. See classifier instructions. The notebook validates inputs and invokes the same CLI with argv lists; it does not upload files, install packages, download a repository, publish artifacts or generate a release model on its own. Do not run it automatically on repository open. reviewed:true in JSON is an ingestion assertion, not proof the Owner actually reviewed/redacted the record.

For a synthetic-only demonstration use the explicit synthetic mode in a separate experiment and label every result **SYNTHETIC ONLY**. It must never satisfy release accuracy, model approval, independent review or physical-device gates. No synthetic experiment is automatically generated or executed by this notebook.

3. Draft Privacy Policy

Version: AQ-PRIV-DRAFT-0.2 · **Prepared:** 7 November 2026 (Asia/Manila)

Status: Draft for review by the operator, designated privacy lead and authorized academic reviewers; organizational adoption is pending.

Effective date: [Owner approval required]

3.1 Personal Information Controller and Scope

This draft covers the Aqua Quenchers Water Refilling Business Management System used by authorized Owner and Staff accounts for the station in General Mariano Alvarez, Cavite, Philippines.

- Personal information controller/legal operator: **[registered business name and authorized representative — confirm before adoption]**.

- Business address: **[complete approved address]**.

- Privacy lead/DPO or authorized contact: **[name or office, approved email/telephone and request channel]**.

The capstone developers support the system under the operator's instructions. Academic governance titles do not create additional application roles. The operator must confirm controller/processor responsibilities and access before real customer data is used.

3.2 Categories of Information and Processing Purposes

Information	Necessary business purpose
Customer name, customer type, contact number and service address	Identify customers, apply the fixed permitted price and arrange collection/delivery
Orders, original and collected quantities, delivery progress, transaction references, balances and cash payment records	Fulfil orders, reconcile gallons and retain accurate commercial records
Expense date, category, amount, optional remarks and recorder	Record approved expenses and produce Owner financial summaries
Staff/Owner name, username, contact, role, active status and stable managed identity	Provide authorized accounts and record responsibility for business actions
Authentication/session and protected audit records	Verify access, revoke sessions, investigate failures and preserve transaction accountability
Approved protected exports and recovery copies	Restore records and meet the operator's approved continuity/retention obligations

Managed authentication processes passwords and any enrolled authentication factors. Passwords, refresh credentials, factor setup secrets and privileged service keys must not be included in public

reports, public images, source code or training data. The BMS does not require payment-card details, government IDs, birth dates, continuous location tracking or a public customer account for ordinary station service.

Protected transaction/audit history may contain necessary customer snapshots. It is restricted business information, not a public log. Optional expense remarks should omit unnecessary personal information.

3.3 Lawful Basis and Transparency

The operator must document the appropriate lawful basis under Republic Act No. 10173 and applicable rules for each actual purpose, including service fulfilment and applicable commercial/legal obligations. Collecting a notice acknowledgement is distinct from obtaining consent to an optional purpose.

The active release does not introduce a marketing program or customer registration portal. Optional marketing must remain disabled unless the operator separately approves the purpose, notice and genuine choice. Refusal or withdrawal of optional consent must not be presented as a request to erase records that must lawfully be retained for a different purpose. Optional-purpose processing requires a separately approved implementation and appropriate records of the applicable legal basis.

3.4 Authorized Access and Data Sharing

Active Owner and Staff accounts share the approved operational customer/order/payment work. Only the Owner may access expenses, financial reports and Staff-account administration. Cloud/database administration and approved recovery/privacy actions require separately designated administrator or custodian access.

Supabase is the selected managed authentication/database platform. The operator must approve the actual project region, provider arrangements and any cross-border processing before launch: **[project region and processor details to confirm]**. Restricted recovery storage and support access require named custodians and separate approval. Public GitHub repositories, presentation slides and academic reports must use code, redacted evidence and synthetic examples rather than customer records, private exports or access secrets.

3.5 Automated Classification Assistance

Expense category assistance is advisory. When an approved model is available, the intended production path performs inference locally in Java on the Android device. The Owner reviews and saves the final category; prediction cannot save an expense or change payments, stock or dates.

A reviewed station dataset and released model are not currently established by this draft. Offline training data must be reviewed, minimized and kept in controlled storage. Raw remarks and customer records must not be packaged in the APK or published as benchmark evidence. The research demonstration adapter is outside the intended production inference path.

3.6 Retention and Disposal

The Owner, privacy lead and accountant must approve the actual retention schedule before adoption. This draft does not invent a statutory retention duration or an automatic deletion commitment.

Record class	Retention/disposal decision required
Current customer contact/address	Service necessity, correction/eligible-removal criteria and review interval
Orders, payments, expenses and commercial history	Applicable accounting/legal obligations and any legal hold
Account, authentication and audit records	Security purpose, minimum necessary evidence and authorized review/disposal
Training/benchmark material	Approved research purpose, minimization and experiment retention
Recovery copies	Approved copy age/expiry, independent protection and restore procedure

The IAS target of seven verified daily recovery copies is a backup-rotation target, not an accounting-retention schedule. Recovery storage, scheduling, key custody and a hosted restore drill still need operational approval/verification. Eligible removals must be reapplied before a restored copy is reopened. Deleting a live record does not establish immediate erasure from every backup; immediate physical or cryptographic erasure is not promised.

3.7 Data Subject Rights and Request Procedures

Customers and account holders may use the approved privacy contact to ask about their information, request access/correction, or seek blocking/removal and other applicable rights. The designated reviewer verifies authority using the minimum information necessary, records the decision and separates eligible personal-field removal from commercial records that have a continuing lawful retention basis.

No password, authenticator secret or privileged key is required in an email/chat rights request. There is no ordinary-app erase-everything control. Requests, response periods, fees if lawfully applicable, refusals and escalation must follow applicable law and the operator's approved procedure. Individuals retain the right to raise concerns with the Philippine National Privacy Commission through its official channels.

3.8 Security Safeguards and Incident Management

The design uses managed authentication, current-role checks, restricted database grants, checked transactions, bounded inputs, protected transport and controlled audit/recovery procedures. Local verification is not certification of the future hosted configuration or actual device operation. Device locks, administrator MFA, real backup custody and release settings require their own evidence.

Suspected incidents must be escalated to the designated response lead for containment, evidence preservation and notification assessment. Where notification conditions apply, the controller must meet applicable NPC requirements, including the applicable 72-hour requirement; an ordinary

application error alone is not proof of a notifiable breach.

3.9 Approval, Effectivity and Revision

Before publication, complete all bracketed operator/contact/region/retention details, review the actual deployment and approve the policy version. Give people the approved notice through the operator's real service channels. Material purpose, provider, retention or access changes require review and an updated notice as appropriate. This draft does not claim that a consent or policy-acceptance event has already been captured in the app.

3.10 Approval Record

Approval responsibility	Required action	Status
Authorized operator	Confirm controller identity, purposes and service channels	Pending
Designated privacy lead	Review lawful bases, rights procedures and incident obligations	Pending
Authorized records/accounting reviewer	Approve retention and applicable holds	Pending
Authorized approving representative	Approve version and effective date	Pending

Implementation and deployment evidence is assessed separately in the Security-Control Assessment. This policy establishes proposed governance obligations; adoption does not itself verify technical compliance.

4. Draft Terms and Conditions

Version: AQ-TERMS-DRAFT-0.2 · **Prepared:** 7 November 2026 (Asia/Manila)

Status: Draft for organizational and academic review; adoption and effective date pending.

Operator: [registered business name, approved address and contact]

Effective date: [to be approved]

4.1 Purpose and authorized users

The BMS supports the station's customer, order, pickup/delivery, inventory, cash-sale, payment, expense and financial-report work. Access is for individually authorized Owner and Staff accounts. There is no public customer registration, public password-reset workflow or customer marketing program in the approved release.

The Owner approves business access. Shared account credentials, impersonation, access after authorization is withdrawn and use outside assigned business duties are prohibited. Application permissions are limited to the approved Owner and Staff roles.

4.2 Account security

Use the approved managed-authentication account, a passphrase of at least 15 characters and required authenticator verification. Keep passwords and factor/recovery secrets private; do not place them in GitHub, public images or ordinary support messages. Use an appropriate device lock and report lost devices or suspected account misuse through the approved contact.

The approved security policy requires reauthentication after 30 minutes of inactivity. Compliance must be verified for the deployed application revision. Backend current-role/active-status checks remain authoritative. Account recovery and lost-factor handling require the designated administrator's identity-verification procedure; knowing a username is insufficient. The operator must verify hosted Auth and recovery settings before production use.

4.3 Correct records and authority

Enter accurate, necessary information and check the selected customer/reference, business date, quantity, amount and final result before confirming work. Quantities are whole gallons; monetary calculations use centavos. The approved fixed rates are PHP 35 per gallon for Household/Walk-in and PHP 30 for Dealer orders; counter Walk-in POS remains PHP 35. The backend controls applicable prices, actors, receipt times, stock reservations and transaction references.

Revenue by order business date, cash received by actual receipt date, expenses by entered expense date and balances as of period end are different measures. Net income in this BMS is payments received minus expenses. A short pickup retains the original request/audit history and adjusts billable quantity under the permitted rules. Delivery progress and payment status are independent.

Do not fabricate collections/deliveries, alter prices or actor fields through a modified client, bypass reservations, overcollect, overpay or delete financial history. Opening inventory requires actual

approved counts and designated administrator control. There is no ordinary-app manual-stock-adjustment or transaction-delete screen.

4.4 Connectivity, confirmation and corrections

Financial writes require a reachable backend. A preview, spinner, prediction or network timeout is not confirmation that a record was saved. When an outcome is unknown, preserve the original request/reference and follow the safe retry/reconciliation procedure; do not create a fresh duplicate transaction to guess the result.

An authorized correction must follow the controlled review process with the affected reference, reason, quantities/amounts/dates and approval. Completed receipts and protected audit evidence are retained as required. Report discrepancies to the designated operator instead of editing the database or concealing an error.

4.5 Permissions and acceptable use

Owner and Staff may perform the approved shared operational work. Expenses, Owner financial reports and Staff-account administration remain Owner-only; account administration requires managed MFA. Staff may edit permitted own-profile details and use the documented order/Walk-in credit payment flows.

Do not distribute credentials, publish personal/financial data, introduce malicious files or models, attempt unauthorized access, deliberately disrupt service or use administrative export/recovery tools without authority. Security tests use isolated synthetic fixtures and approved scope; the academic exercise does not authorize probing other people's or production systems.

4.6 Privacy, reports and assisted categories

Handle customer/account/transaction information according to the approved Privacy Policy and retention instructions. Export PDFs only to authorized destinations and protect downloaded/shared files. Academic presentations and public repositories must use synthetic or appropriately redacted examples.

Category suggestions, when an approved release model is supplied, assist the Owner and require review. An uncertain/unavailable suggestion does not authorize a category or a save. Manual expense entry remains available. No accuracy, device-speed or production-recovery target is asserted merely because code or a synthetic test exists.

4.7 Availability, custody and business responsibilities

The operator approves device/network readiness, administrator/recovery contacts, initial stock, retention decisions and independent backup/key custody. Backup and restoration targets require actual monitored exports and a verified drill. Follow the approved continuity record and later reconciliation procedure during outages; do not simulate a successful backend save.

The system's records and reports do not replace physical stock checks, accounting review, water-quality testing or applicable business obligations. Maintenance, limitations and changes must be communicated through the operator's approved channels. This draft does not waive

non-waivable rights or excuse unauthorized or negligent handling of records.

4.8 Suspension, inquiries and adoption

The authorized operator may deactivate an account or restrict work when authority ends, a device is lost, misuse is suspected or containment is necessary, subject to applicable obligations. Session revocation and business-history retention follow the documented procedures.

Support/privacy/security contact: **[approved channel required]**. Applicable Philippine law governs to the extent appropriate to the approved operator arrangement; any dispute/complaint process and contract wording require review before adoption.

Complete operator/contact/effective-date fields and obtain the designated approval before using these terms. Acceptance procedures shall be approved and implemented before these terms take effect; this draft records no executed acceptance agreement.

4.9 Approval Record

Approval responsibility	Required action	Status
Authorized operator	Confirm service scope, account responsibilities and support channel	Pending
Designated privacy or legal reviewer	Review applicable obligations and policy consistency	Pending
Authorized approving representative	Approve version, acceptance process and effective date	Pending

5. Security-Control Assessment

Document identifier: AQ-IAS-03

Edition: 1.0

Issue date: 7 November 2026

5.1 Assessment Scope and Evidence Classification

The assessed application is the owner-module revision bf2b43e, retained as the application base of algo-ias. Detailed implementation links in the matrix refer to the separate reference baseline 424c701 unless otherwise stated. The extended reference review included local revision de7a03b. Reference controls and retained tests are comparative evidence; integration and equivalent behavior on the assessed application branch require independent verification.

Source-reviewed indicates a control traced in the specified source. **Locally verified** identifies retained local or synthetic test evidence at its recorded revision. **Blocked** identifies a missing external approval, configuration or observation. These classifications do not constitute production verification or organizational acceptance.

5.2 IAS Engineering Control Matrix

IAS ticket / recommended control	Implementation	Evidence and remaining gate
SEC-TASK-101: keep privileged keys out of client/source/artifacts	Public-only build guard, server environment only in Edge Auth, .gitignore, account runbook	Source-reviewed; retained native build and public-key restrictions documented in account security. Public Supabase URL/publishable key is expected. Hosted secret inventory, real leak rotation and recurring approved secret scanner remain Blocked. No scan is claimed to prove absence of every possible secret.
SEC-TASK-102: enforce least privilege/RLS and prevent injection	Core grants/RLS/checked RPC, current identity administration, current query	Source-reviewed; SQL negative cases, retained local PostgreSQL checks and real-service scope. Apply all migrations in order; inspect actual hosted grants, exposed schemas and signed JWT settings before release.
SEC-TASK-103: authenticated encrypted backups and separate key custody	age packaging/verification, custodian exporter, runbook	Locally verified fixture encryption/tamper/path checks: recovery-test.log. Real restricted destinations, key custodians and access reviews Blocked; neither client devices nor public GitHub artifacts are backup destinations.
SEC-TASK-104: independent copies, age monitoring and restore	Retention/monitoring, gated private schedule, restore/erasure procedure	Retained populated isolated restore and retention fixture. Seven verified daily copies, monitored 24-hour RPO, eight operating-hour RTO and independent hosted restore evidence remain Blocked. A ciphertext file round-trip is not an operational restore drill.
SEC-TASK-105: current identity, idle timeout, revocation and local cleanup	Server session migration, native session/lifecycle, HTTPS/token transport, manifest	Source-reviewed; retained real local Auth/session/native checks and login integration. Tokens are memory-only, backups disabled, secure window set; no insecure fallback store. Actual lost-device/lock/custody and hosted refresh/session policy remain Blocked. Remote logout failure still requires local cleanup; do not promise successful provider invalidation on a failed network request.
SEC-TASK-106: price/payment/stock integrity and protected audit	Checked transactional command, financial schema/API, idempotency and concurrency fixtures	Source-reviewed; concurrency proof, connected workflow evidence. Server derives actor/time and PHP 35/30 price, uses whole gallons/centavos, locks and exact payload-bound retry IDs. Receipts, reservations and audit commit together. Hosted equivalence/approved real opening counts remain Blocked.
SEC-TASK-107: classifier authority, label/model integrity and manual fallback	Strict model loader, suggestion lifecycle, asset gate, training contract	Retained Python synthetic checks and Java 155 assertion evidence in build record. Seven-label whitelist, digest/size/schema validation, stale cancellation and explicit Owner confirmation are source-reviewed. Real labels/model, Android parity and physical-device benchmark remain Blocked. No model suggestion saves an expense.

5.3 Authentication, Application and Operational Controls

Control objective	Actual implementation/control	Review/limitation
API authentication/session/logout	username-login, managed /auth/v1/*, checked aq_me/aq_logout; Auth handlers	Native bearer protocol; managed provider and checked application endpoints. Managed Auth validates identity and SQL rechecks current active profile/session. Source-IP header sanitization is a deployment validation item.
Protected transactions/session database context	Private schema, hardened SECURITY DEFINER checked RPCs, auth.uid(), current protected profile and session ID	The implementation uses checked PostgreSQL RPCs; service authority stays in Edge administrative paths and never selects financial actor/price on a client's assertion. Active Staff intentionally share station operational records.
Safe atomic audit	Server-owned audit_events written inside checked mutations; default-deny direct table grants	Audit is protected from ordinary app edits/deletes. It is a database log, not a link-ordered cryptographic chain against privileged administrators.
Mobile transport and failure handling	Backend: HTTPS, redirects disabled,15/20 seconds timeouts,4 MiB response cap; bounded same-intent retry	A failed/timed-out mutation is not proof of rollback. Reconcile/retry the same request ID; do not replay as a new financial intent. Unpaginated query growth remains a documented hardening/correctness concern.
Mobile lifecycle/secure storage	Session generations, current-role checks, idle reauthentication, password/MFA exclusion from saved state, memory-only tokens	Android token persistence is not implemented in the reference baseline. Keystore protection is required if persistence is introduced. Provider password-change reauthentication policy must be checked independently of the native screen.
Shared validation/permissions	Rules.java, strict Edge DTOs and SQL validation, API contract	Client validation improves feedback; direct RPC checks remain authoritative. Safe errors avoid raw credential/SQL dumps.
Login abuse protection and MFA	HMAC per-alias/source throttles, minimum15 password, Owner+AAL2 account administration	Node Auth fixtures, retained auth-node.log. Gateway source-header replacement, hosted password/JWT/factor policy and alert delivery need owner-observed evidence.
Privacy, rights and retention	Draft notice, administrator rights/correction process, eligible-contact removal	Dry-run approval, unsettled-operation guard and snapshot cleanup preserve financial history/retry hashes. Approval, commercial retention and independent erasure-ledger custody Blocked. No erase-everything/customer-deactivation UI or optional-marketing consent claim.
PDF/data disclosure	Owner report export, PDF renderer	Explicit current-Owner SAF export; protect the destination afterward. No automatic public report upload or WebView rendering.
Dependency/build/runner controls	Fixed dependency versions/repositories, Gradle distribution SHA, no privileged PR checkout, private+enabled backup gate	Source-reviewed. Full transitive hash locking/SBOM/CVE monitoring, hosted branch protection, signing/release/custody evidence remain open. A version pin alone is not a vulnerability scan.

Control objective	Actual implementation/control	Review/limitation
Incident response	Account recovery/revocation, restricted copies and restore procedure, draft privacy incident section	Named contacts, escalation, applicable Philippine breach-notification assessment, actual monitoring and rehearsals need operator/privacy-lead review. Never log passwords, recovery keys or real customer payloads to prove an incident.

5.4 Verification and Acceptance Requirements

Complete the owner-observed deployment validation steps in the Cloudflare report; obtain named ticket reviewers' and Owner acceptance; run declared-device/Figma/usability and actual reviewed-model gates. Do not weaken any authorization, transaction-integrity or classifier acceptance rule to close a ticket. Traceability retains functional status separately from these source-review results.

6. Security Assessment Methodology and Status

Document identifier: AQ-SEC-01

Edition: 1.0 — Interim Technical Assessment

Issue date: 7 November 2026

6.1 Objective and Scope

The assessment examines authentication, authorization, transaction integrity, mobile session handling, classifier artifacts, administrative recovery and build/deployment controls. The assessed application branch derives from owner-module revision bf2b43e. A separate extended source assessment concerns local revision de7a03b, based on reference revision 424c701. Results are attributed to their respective revisions and do not establish equivalent implementation on another branch.

6.2 Assessment Method

The reference assessment applied the source-first workflow of Cloudflare security-audit at its pinned revision. Activities comprised architectural reconnaissance, trust-boundary identification, deterministic coverage planning and six independent subsystem source reviews. A security candidate required a source-grounded boundary trace; a confirmed finding additionally required bounded observed evidence. Missing best practices were classified separately from demonstrated vulnerabilities.

No new target-controlled execution or deployed-endpoint testing was performed in this assessment. Existing local functional evidence is retained under its original scope and revision. The assessment did not access production identities, alter application records, perform load testing or deploy services.

6.3 Recorded Coverage

Measure	Recorded result
Planned and source-reviewed coverage units	77
Units closed through source review without a retained candidate	75
Units linked to one unresolved candidate	2
Unique unresolved candidate	1
Confirmed vulnerabilities established by this assessment	None established
Independent coverage criticism	Not completed
Independent candidate and final-record verification	Not completed
Final comprehensive audit status	Incomplete

These counts describe review coverage, not a count of passed penetration tests or proof of an absence of vulnerabilities. The coverage ledger passed its structural validator. The subsequent independent coverage-critic stage was interrupted by an execution-resource limit. The required final coverage and finding-verification stages remain outstanding; a completed Cloudflare audit report cannot yet be issued.

6.4 Unresolved Validation Item

The reference username-login implementation derives its aggregate source-throttling key from the first x-forwarded-for value. The security property depends on the effective gateway replacing or authenticating caller-supplied forwarding metadata. Per-username throttling remains independently enforced. Gateway behavior and attachment were not established, and no bypass was demonstrated. The item has no assigned vulnerability severity pending independent validation.

Validation requires review of the effective ingress policy and a bounded isolated fixture using synthetic requests. A deployed production service shall not be probed to resolve this documentation item.

6.5 Limitations and Completion Criteria

The assessment does not establish hosted configuration, branch protection, signing-key custody, recovery-destination permissions, operational restoration performance or physical-device behavior. Completion requires independent coverage criticism, resolution of accepted coverage gaps, candidate verification, final-record verification and consistent final reporting. Application-branch findings require their own validation against the active source.

Related assessments are the Application Branch Assessment, OWASP Agentic Skills Assessment and Security-Control Matrix.

7. Application Branch Assessment

Document identifier: AQ-SEC-02

Edition: 1.0 — Source Assessment

Issue date: 7 November 2026

Assessed revision: bf2b43ea2ce0731ff145f5aad421979f9d3b6a7a

7.1 Scope

The assessment concerns the owner-module application source inherited by algo-ias. The separate reference baseline 424c701 is not integrated by the documentation changes. Source observations below require independent behavioral verification before security acceptance.

7.2 Source-Reviewed Controls

The identity Edge handler verifies managed bearer identity and current active profile status. Account administration includes Owner and managed AAL2 checks. Protected SQL business operations use authorization checks, direct-write restrictions, row-level security and transactional financial audit records. Native session credentials are held in process memory, and the application manifest disables backup. A Supabase endpoint and publishable key constitute public client configuration rather than a privileged service credential.

7.3 Validation and Remediation Register

Area	Source observation	Required verification or action
Asynchronous identity binding	Refresh/replay and MFA completion paths lack originating-session generation guards	Validate logout/account-switch sequences with delayed responses; bind completion to the originating identity and session
Logout and revocation	Local cleanup does not demonstrate provider session revocation	Verify remote invalidation, failed-network behavior and rejection of prior credentials
Inactivity	Active-profile SQL guard does not enforce the specified server idle period	Implement and verify server-side inactivity enforcement consistent with approved policy
Account administration audit	Audit recording is separate from managed identity mutation	Validate partial failures and establish accountable reconciliation without false success
Retry intent	Retry handling does not compare the complete changed payload intent	Verify identical retry behavior and conflict rejection for changed intent
Failure reporting	Ambiguous network failures may be described as no save	Use outcome-accurate feedback and deterministic reconciliation of unknown outcomes
Classifier integration	The application explicitly reports classifier unavailability	Integrate the reviewed advisory classifier, strict artifact checks and explicit Owner confirmation; preserve manual entry

The register identifies source observations and engineering work. It does not assign exploit severity or claim a confirmed cross-principal attack without the applicable validation.

7.4 Algorithm and Operational Acceptance

The application branch does not currently provide the completed in-app classifier demonstration. Empirical evaluation additionally requires an Owner-reviewed anonymized corpus, an approved model and the declared physical tablet. Hosted Auth/grants, independent recovery custody, restoration and device controls remain unverified. Privacy and authorized-use documents require organizational adoption.

7.5 Source References

- Application Java source
- Assessed source revision
- Reference implementation revision

8. OWASP Agentic Skills Assessment

Document identifier: AQ-SEC-03

Edition: 1.0 — Manual Applicability Assessment

Issue date: 7 November 2026

8.1 Assessment Basis

This assessment applies the official OWASP Agentic Skills Top 10 checklist at revision d6f7d7d0de314f52a83a85d1828e06ab096e595c to the AI-assisted development workflow. The business application contains no autonomous runtime agent. Expense classification is advisory numerical inference and does not execute natural-language instructions or invoke privileged tools.

The assessment is a manual applicability and gap analysis. It does not constitute certification, a completed automated scan or proof of runtime isolation. The framework's category risk labels shall not be interpreted as severity assignments for unconfirmed application findings.

8.2 Assessment Matrix

Risk	Observed safeguard / remaining gap
AST01 Malicious Skills	Exact publisher sources reviewed; signed-publisher and dynamic-canary verification absent
AST02 Supply Chain Compromise	Skill commits pinned; complete signed dependency/SBOM verification absent
AST03 Over-Privileged Skills	Source-only hunters restricted by instructions; full per-agent OS permission isolation not established
AST04 Insecure Metadata	Metadata treated as untrusted instructions; full metadata schema/behavior scanner not run
AST05 Untrusted External Instructions	User documents separated from user authorization; paper snapshots hashed; transitive external graph not fully audited
AST06 Weak Isolation	No new target code executed during audit because complete required resource/isolation controls were not established
AST07 Update Drift	Review revisions pinned; future changes require re-review; automatic advisory/update gate absent
AST08 Poor Scanning	Multi-subsystem source review performed; independent audit phases interrupted, no claim of comprehensive dynamic/SAST/CVE scanning
AST09 No Governance	Persistent scope/checkpoint and source refs retained; formal organizational inventory/revocation/review cadence pending
AST10 Cross-Platform Reuse	Android/Supabase and development-agent boundaries distinguished; no cross-platform certification

8.3 Interpretation and Required Follow-up

Pinned source revisions and documented scope support repeatable review. Complete signed dependency verification, metadata/behavior analysis, enforceable per-agent isolation, independent dynamic assessment and organizational governance remain incomplete. Application web/mobile controls are assessed separately through the IAS control matrix; an agentic-workflow checklist does not replace them.

The community scholarly360/owasp-top10-web-skills reference at revision b066b36aa62cd576d02ddf91edabe7359059fcf8 is separate from the official OWASP Agentic Skills project. No completed execution of that community pack is claimed.

8.4 Reference

OWASP. (n.d.). Skill Security Assessment Checklist. OWASP Agentic Skills Top 10. Reviewed source revision as identified above.

9. Acceptance Criteria and Outstanding Evidence

Workstream	Required acceptance evidence	Current disposition
Academic milestones	Current ALGOCOM and IAS documents with version reconciliation	Source documents registered; subsequent changes require reconciliation
Policy adoption	Approved controller identity, contacts, lawful bases, retention and effective dates	Organizational approval pending
Application controls	Verified implementation and negative/positive tests on the actual application revision	Source observations documented; integration and independent validation outstanding
Classifier integration	Strict approved-model loading, advisory suggestions, stale-result handling and explicit Owner confirmation in the application	Not integrated into the assessed application branch
Predictive quality	Reviewed grouped held-out evidence meeting frozen macro-F1 and category-recall criteria	Dataset/model evidence pending
Device performance	Declared-tablet latency, Java heap and separate process-memory measurements	Physical-device evidence pending
Security assessment	Independent coverage criticism, candidate verification and final verified report	Independent assessment stages incomplete
Recovery readiness	Independent protected copies, key/ledger custody, monitored copy age and timed isolated restoration	Operational evidence pending
Deployment	Approved hosted configuration and release decision	Production deployment deferred

The benchmark notebook has been provided without stored execution outputs. Numerical results shall be added only after the corresponding approved procedure has been executed and its evidence retained. A failed acceptance criterion shall be reported at its original threshold. Policy adoption and operational readiness require separate authorized decisions.

10. References

1. Aqua Quenchers project group. (n.d.). *Algorithms and Complexity milestone*. https://docs.google.com/document/d/1ad4xmnPsoNZSpVCHALvLoQ5zGRYaHF0hEQ5UhTwF4_o/edit

2. Aqua Quenchers project group. (n.d.). *Information Assurance and Security milestone*. https://docs.google.com/document/d/1irULKgUcm4PbGIXDn3hNofR9M5Ou4VDE/edit

3. Aqua Quenchers project repository. (n.d.). *Application source*, revision bf2b43ea2ce0731ff145f5aad421979f9d3b6a7a. https://github.com/deo-ganub/Aqua-Quenchers-BMS/tree/bf2b43ea2ce0731ff145f5aad421979f9d3b6a7a

4. Aqua Quenchers project repository. (n.d.). *Reference implementation*, revision 424c70112d22e37dccdef41e5471e283587c0726. https://github.com/deo-ganub/Aqua-Quenchers-BMS/tree/424c70112d22e37dccdef41e5471e283587c0726

5. Cloudflare. (n.d.). *Security audit skill*, revision c1c8a8c1471069fb0e188eeaff69b8e8db6564a8. https://github.com/cloudflare/security-audit-skill/tree/c1c8a8c1471069fb0e188eeaff69b8e8db6564a8

6. OWASP. (n.d.). *Skill security assessment checklist: Agentic Skills Top 10*, revision d6f7d7d0de314f52a83a85d1828e06ab096e595c. https://github.com/OWASP/www-project-agentic-skills-top-10/blob/d6f7d7d0de314f52a83a85d1828e06ab096e595c/checklist.md

7. Republic of the Philippines. (2012). *Republic Act No. 10173: Data Privacy Act of 2012*. https://lawphil.net/statutes/repacts/ra2012/ra_10173_2012.html

The academic-source snapshots reviewed on 6 November 2026 are identified by SHA-256 in the accompanying IAS source register. The preparation of this report does not alter those source documents or establish independent approval of their proposals.